Bloomin' Acres

PROJECT STATUS REPORT

Prepared by OphidianAI

March 7, 2026

Version 3.0

INTELLIGENCE, ENGINEERED.

Executive Summary

Full-stack e-commerce platform for a sourdough bakery and fresh produce business.

7.8
out of 10

OVERALL SCORE

Security	8.5 / 10 ↑
Checkout	8.5 / 10 ↑
SEO	8 / 10
Navigation	8 / 10
Accessibility	8 / 10 NEW
Mobile	8 / 10 ↑
Performance	7.5 / 10 ↑
Visual Design	7 / 10
Code Quality	7 / 10 ↑
User Journey	7 / 10

Tech Stack

HTML / CSS / JS · Supabase · Stripe · Vercel · Supabase Auth · Supabase Storage · Stripe Checkout · Stripe Webhooks

Project Status

AREA	STATUS	NOTES
Landing Page	LIVE	CMS-driven content, dynamic hero/cards/hours/contact
Public Menu	LIVE	Stripe product sync, section editor, draft preview
Product Pages	LIVE	Variations, stock tracking, inline admin editor
Customer Accounts	LIVE	Cart, favorites, orders, profile, club dashboard
Bread Box Club	LIVE	Subscriptions, box builder, referral rewards
Admin Dashboard	LIVE	7 tabs: catalogue, menu editor, saved menus, landing, orders, analytics, club

AREA	STATUS	NOTES
Checkout Flow	LIVE	Order review modal, stock validation, variation pricing. CORS locked to production.
Performance	DONE	Images optimized (42 MB → 2.4 MB), shared JS extracted, caching headers configured
SEO	DONE	Meta tags, Open Graph, JSON-LD, canonical tags, sitemap.xml, robots.txt deployed
Security	DONE	CSP, HSTS, X-Frame-Options, nosniff, Referrer-Policy, Permissions-Policy
Accessibility	DONE	Skip-to-content links, 44px touch targets, focus indicators, ARIA labels

What Changed

Updates since Version 2.0 (March 7, 2026)

Security Hardening

Content-Security-Policy & Security Headers

Full CSP with whitelisted sources (Tailwind CDN, Supabase, Google Fonts, jsdelivr). HSTS with 2-year max-age + preload. X-Frame-Options: DENY, nosniff, Referrer-Policy, Permissions-Policy. All configured via `vercel.json`.

Static Asset Caching Headers

Brand assets: 1-year immutable cache. CSS/JS: 1-day cache with 7-day stale-while-revalidate. Configured via `vercel.json` headers.

Checkout & UX Improvements

Order Review Modal

Customers now see a confirmation modal with itemized order summary (names, quantities, variations, total) before being redirected to Stripe. Cancel button returns to cart.

Cart Stock Validation (Client + Server)

Review modal checks current stock levels from Supabase. Over-stock items highlighted in red with availability info. Confirm button disabled if stock insufficient. Server-side validation in `/api/stripe/checkout` prevents overselling.

SEO & Accessibility

Dynamic Product Meta Tags

Product pages now update `<title>`, `og:title`, `og:description`, `og:image`, `og:url`, and `<link rel="canonical">` dynamically based on the loaded product.

Canonical Tags on All Pages

Added `<link rel="canonical">` to index, menu, club, and account pages. Product pages generate canonical URLs dynamically.

Accessibility: Skip Links & Touch Targets

Skip-to-content link on all 5 public pages (visually hidden, visible on focus). Avatar touch target increased from 30px to 44px (WCAG 2.5.5). Form inputs set to 44px min-height.

Facebook Social Link Updated

Footer Facebook icon now links to the actual business page (`facebook.com/bloominoven`).

Current Features

Customer-Facing Pages

Landing Page (index.html)

CMS-driven hero, product cards, hours, contact info. Admin-editable via landing tab.

Public Menu (menu.html)

Auto-synced from Stripe products. Section editor, drag-and-drop ordering, draft preview.

Product Detail (product.html)

Dynamic product pages with variation selector, stock badge, image gallery, admin inline editor.

Bread Box Club (club.html)

Subscription landing page with tier comparison, box builder, referral program, and member dashboard.

Account Dashboard

Cart & Checkout

Slide-out cart panel, quantity editing, Stripe Checkout redirect, order confirmation.

Favorites

Heart-toggle on product cards, persistent favorites list on account page.

Order History

Past orders with line items, totals, and status badges pulled from Stripe webhooks.

Profile Management

Name, email, phone, address. Password change via Supabase Auth.

Admin Dashboard

Catalogue Management

CRUD for products, variations, images, stock levels. Syncs to Stripe.

Menu Editor

Drag-and-drop section builder, product assignment, draft/publish workflow.

Landing Page Editor

Edit hero text, featured products, hours, and contact info in real time.

Order Management

View all orders, filter by status, mark as fulfilled.

Analytics

Club Management

Revenue chart, top products, order count, customer metrics.

Manage subscription tiers, view active subscribers, referral tracking.

Saved Menus

Save and restore menu configurations for seasonal rotations.

Backend & Integrations

Supabase Database

TABLE	PURPOSE	RLS
profiles	User profile data (name, phone, address)	ON
products	Product catalogue with Stripe sync	ON
product_variations	Size/type variations with price deltas	ON
orders	Order records from Stripe webhooks	ON
order_items	Line items for each order	ON
favorites	User product favorites	ON
cart_items	Persistent cart storage	ON
menu_sections	Menu layout configuration	ON
menu_section_products	Product-to-section assignments	ON
saved_menus	Saved menu configurations	ON
landing_content	CMS content for landing page	ON
subscriptions	Bread Box Club subscription records	ON
referrals	Referral tracking for club members	ON

Stripe Integration

ENDPOINT	PURPOSE
/api/stripe/checkout	Create Checkout Session for cart items
/api/stripe/subscribe	Create subscription checkout for Bread Box Club
/api/stripe/webhook	Handle payment confirmation, order creation
/api/stripe/config	Expose publishable key to frontend

Storage Buckets

BUCKET	PURPOSE	PUBLIC
product-images	Product photos uploaded by admin	YES
brand-assets	Logo, hero images, background textures	YES

Priority Issues

Open Issues

1. Massive Inline Scripts CODE QUALITY

`account.html` has ~900 lines of inline JS. `product.html` ~620 lines. Not cacheable, not minifiable, not testable. Blocks HTML parsing on every page load.

2. No Guest Checkout UX

All purchases require account creation. No option for one-time buyers to check out without signing up. Potential conversion blocker.

3. Duplicated Utility Functions CODE QUALITY

`showToast()`, `escHtml()`, `formatPrice()` defined independently in 3 pages with inconsistent toast durations (2.8s, 3.0s, 3.2s). Should extract to shared `js/utils.js`.

4. Instagram Social Link Placeholder CONTENT

Footer Instagram icon links to generic `instagram.com`. Waiting on client to provide their Instagram handle.

Previously Resolved

ISSUE	STATUS
No Content-Security-Policy headers	RESOLVED
No order review before payment	RESOLVED
Product pages lack dynamic SEO	RESOLVED
Cart has no stock validation	RESOLVED
Undersized touch targets	RESOLVED
No skip-to-content links	RESOLVED
No canonical tags	RESOLVED
No static asset caching	RESOLVED

ISSUE	STATUS
Checkout variation pricing bug	RESOLVED
Cart missing variation names	RESOLVED
CORS wildcard headers	RESOLVED
Missing SEO meta tags	RESOLVED
Checkout back-button disabled	RESOLVED
Copyright year inconsistency	RESOLVED

Optimization Suggestions

Performance (Score: 7.5/10)

HIGH IMPACT

Extract Inline Scripts to External Modules

`account.html` has ~1,200 lines of inline JS. External files are cacheable, minifiable, and testable. Biggest single performance win available.

HIGH IMPACT

Replace Tailwind CDN with Compiled Build

CDN loads ~350 KB per page. Compiling to used classes only would cut this to ~10-15 KB. Config already extracted to `tailwind-config.js`.

MEDIUM IMPACT

Cache Stripe API Responses

Menu page fetches all Stripe products on every load. Add a short TTL cache or edge function cache to reduce latency and API calls.

DONE

Static Asset Caching Headers

Brand assets: 1-year immutable. CSS/JS: 1-day with 7-day stale-while-revalidate. Configured via `vercel.json`.

DONE

Image Optimization

42 MB → 2.4 MB (-94%). WebP conversion, source files relocated. Automated pipeline via `scripts/optimize-images.mjs`.

Architecture (Score: 7/10)

HIGH IMPACT

Add Build Pipeline

Raw HTML/CSS/JS served directly. No minification, bundling, or tree-shaking. An esbuild or Vite setup would improve load times and enable module imports.

PARTIAL

Shared Nav Component

Nav JS extracted to `shared.js`. Nav HTML still duplicated across 6 pages. Extract to a template or web component.

MEDIUM IMPACT

Shared Utility Module

`showToast`, `escHtml`, `formatPrice` duplicated across pages. Extract into a single `js/utils.js` file.

UX (Score: 7/10)

DONE

Order Review Step Before Payment

Confirmation modal shows itemized summary with quantities, variations, and total. Stock validated before confirm. Disable button if stock insufficient.

DONE

Product Price Live Update on Variation Select

Selecting a variation pill updates the displayed price in real time to reflect the delta.

DONE

Accessibility: Skip-to-Content and Touch Targets

Skip-to-content on all pages. Avatar 36px with 44px touch area. Form inputs min-height 44px. Focus-visible styles on all interactive elements.

Suggested Features

E-Commerce & Ordering

Pickup Time Slots

Let customers choose a pickup window at checkout. Reduces crowding and improves the experience.

Order-Ahead / Pre-Order

Accept orders for items baked on specific days. Sourdough schedules could drive pre-order demand.

Discount / Promo Codes

Stripe Coupons integration for seasonal promotions, first-time buyer discounts, and referral rewards.

Customer Engagement

Email Notifications

Order confirmation, shipping/pickup ready, and weekly menu announcements via transactional email.

Product Reviews

Star ratings and text reviews on product pages. Builds trust and provides social proof.

SEO & Discoverability

Structured Data (JSON-LD)

LocalBusiness, Product, and BreadcrumbList schema for rich search results.

Sitemap & Robots.txt

Auto-generated sitemap for product and menu pages. Proper robots.txt to guide crawlers.

Admin & Operations

Inventory Alerts

Notify admin when stock falls below threshold. Prevents overselling.

Sales Export

CSV export of orders and revenue for bookkeeping and tax prep.

Content

Blog / Recipes

About Page

Simple blog for sourdough tips, farm updates, and recipes. Drives organic traffic and engagement.

Farm story, team photos, mission statement. Builds emotional connection with customers.

Code Quality Assessment

Strengths (Score: 7/10)

- **Clean Supabase integration** -- RLS policies on all tables, proper auth flow, parameterized queries
- **Stripe best practices** -- Webhook signature verification, idempotent order creation, PCI-compliant checkout
- **Admin/customer separation** -- Role-based UI with admin-only sections properly gated
- **CMS-driven content** -- Landing page and menu fully editable without code changes
- **Modular API layer** -- Separate files for checkout, subscribe, portal, products, webhook
- **XSS prevention** -- `escHtml()` used on user-facing product names and descriptions
- **Stock validation** -- Dual client + server validation prevents overselling at checkout
- **Security headers** -- CSP, HSTS, X-Frame-Options, nosniff, Referrer-Policy configured

Areas for Improvement

- **Massive inline scripts** -- `account.html` has ~1,200 lines of inline JS. Not cacheable, not testable, blocks parsing.
- **No build pipeline** -- Raw HTML/CSS/JS served directly. No minification, bundling, or tree-shaking.
- **Tailwind CDN** -- ~350 KB loaded per page. Should compile to used classes only (~10-15 KB).
- **Variable naming inconsistency** -- `sb` vs `supabase`, `currentUser` vs `session.user` across pages.
- **Magic numbers** -- Toast timeouts (3000ms, 2800ms), no centralized constants.
- **No error boundaries** -- Network failures in product/menu loads show no fallback UI.
- **Duplicated fetch patterns** -- `/api/config` fetched on every page without session caching.

Security Posture (Score: 8.5/10)

AREA	STATUS	NOTES
Authentication	GOOD	Supabase Auth with email/password. Session management handled by SDK.
Row-Level Security	GOOD	RLS enabled on all tables. Policies restrict access by user ID and role.
Payment Security	GOOD	Stripe Checkout handles PCI compliance. No card data touches the server.
Webhook Verification	GOOD	Stripe webhook signature verified before processing.

AREA	STATUS	NOTES
CORS Policy	GOOD	Locked to `ALLOWED_ORIGIN` env var. Production set to `bloominacresmarket.com`.
Input Sanitization	GOOD	Supabase parameterized queries. `escHtml()` on rendered content.
Content-Security-Policy	GOOD	Full CSP with whitelisted sources. `unsafe-inline` required until scripts extracted.
HTTPS Enforcement	GOOD	HSTS configured with 2-year max-age, includeSubDomains, and preload directive.
Stock Validation	GOOD	Client-side check in review modal + server-side enforcement in checkout API.